

Skill swap

Owner: Olesia Baidala & Khrystyna Bat
Reviewer:
Contributors:
Date Generated: Tue Dec 16 2025

Executive Summary

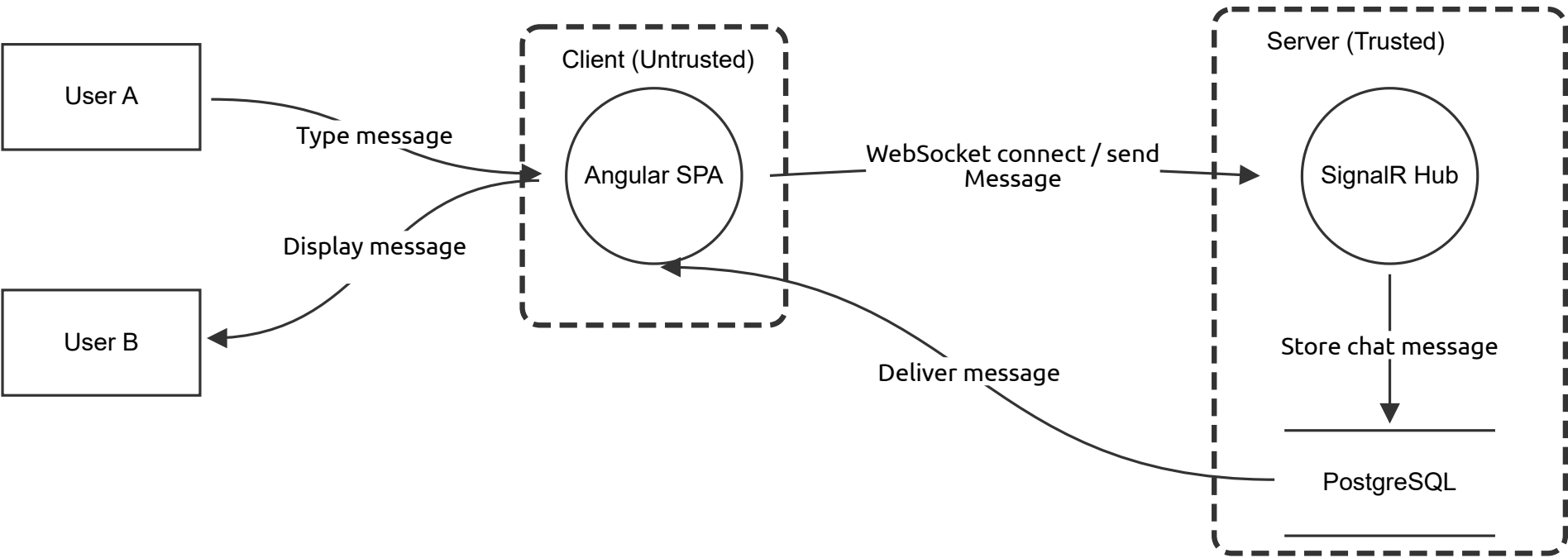
High level system description

Not provided

Summary

Total Threats	16
Total Mitigated	16
Total Open	0
Open / Critical Severity	0
Open / High Severity	0
Open / Medium Severity	0
Open / Low Severity	0

Chat (SignalR) → Message delivery



Chat (SignalR) → Message delivery

SignalR Hub (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
15	Unauthorized access to chat history (IDOR)	Elevation of privilege	High	Mitigated	8	An attacker may gain access to chat messages or join conversations they are not authorized to participate in by manipulating chat identifiers.	Verify chat participation for every message and history request and enforce strict server-side authorization checks.
16	Sender spoofing in chat messages	Spoofing	Medium	Mitigated	7	An attacker may attempt to impersonate another user by forging sender identifiers in chat messages.	An attacker may attempt to impersonate another user by forging sender identifiers in chat messages.
19	Missing audit logs for chat operations	Repudiation	Low	Mitigated	4	Without audit logs, chat-related actions such as sending or deleting messages cannot be reliably traced or investigated.	Log chat events including message creation, deletion, user identifiers, chat identifiers, timestamps, and source metadata.

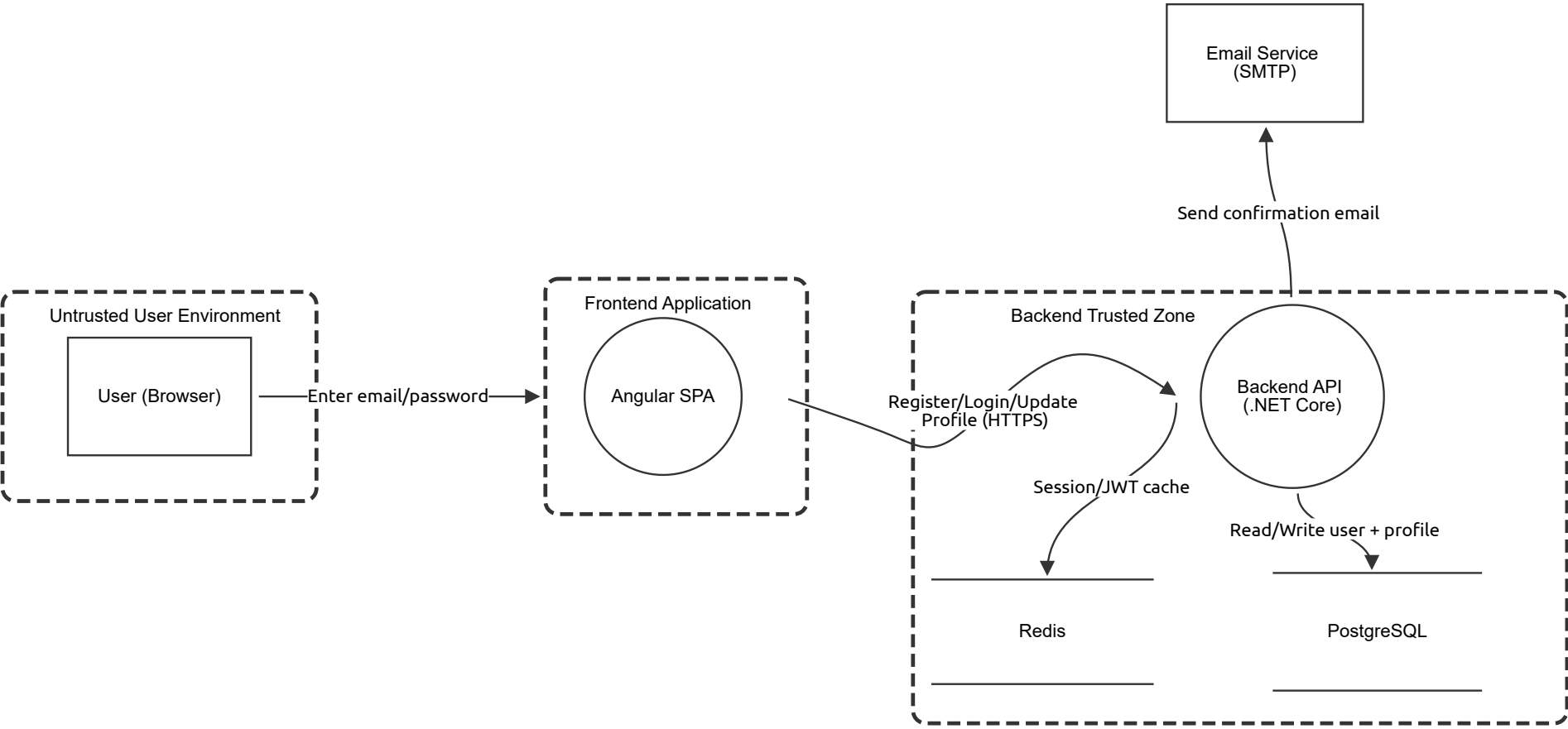
WebSocket connect / send Message (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
17	Replay attack on chat messages	Tampering	Medium	Mitigated	5	Previously sent chat messages may be replayed by an attacker, causing duplicate message delivery or message order confusion.	Use message identifiers or timestamps, reject duplicate or outdated messages, and validate message ordering on the server.
18	Message flooding / Chat Denial of Service	Denial of service	Medium	Mitigated	6	An attacker may send a high volume of chat messages to overwhelm the SignalR Hub or backend resources, degrading service availability.	Apply rate limiting per user and per connection, throttle message sending, and disconnect abusive or misbehaving clients.

Display message (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
14	Cross-Site Scripting (XSS) via chat messages	Tampering	High	Mitigated	8	Malicious script content embedded in chat messages may be rendered in the recipient's browser, resulting in client-side code execution.	Disallow HTML in chat messages, sanitize message content on the server, escape output on the client, and enforce a strict Content Security Policy (CSP).

Registration → Login → Profile management



Registration → Login → Profile management

Angular SPA (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
4	JWT theft via XSS / insecure token storage	Information disclosure	High	Mitigated	8	Tokens may be stolen from the browser via XSS or insecure storage (e.g., localStorage), enabling account takeover.	Store access tokens in HttpOnly+Secure cookies, short-lived access tokens (15–20 min), refresh token rotation, and CSP to reduce XSS impact.

Backend API (.NET Core) (Process)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
6	Stored/Reflected XSS in profile fields (Name/Bio/City/Skills)	Tampering	High	Mitigated	7	Malicious script content may be stored in profile fields and executed in other users' browsers when viewing a profile.	Server-side validation + sanitization of user-generated fields, disallow HTML/rich text, output encoding on the client, and CSP.
7	SQL Injection in /auth and /profile	Tampering	Critical	Mitigated	10	Improper input handling may allow injection of malicious SQL affecting data integrity and confidentiality.	Use ORM/parameterized queries, avoid dynamic SQL, strict input validation, least-privilege DB account, and automated tests for injection.
8	IDOR access/edit other users' profiles via /api/profile/{id}	Elevation of privilege	High	Mitigated	8	Attacker may access or modify other users' profiles by manipulating identifiers in requests if authorization checks are missing.	Enforce ownership/authorization checks on every profile operation; derive userId only from JWT (token subject), never trust id from URL/body.
9	CSRF on state-changing profile endpoints	Elevation of privilege	Medium	Mitigated	6	A malicious site could trigger a victim's browser to send authenticated requests (e.g., update profile) without user intent.	SameSite cookies (Lax/Strict), CSRF tokens (double submit or server-issued), verify Origin/Referer for state-changing requests.
12	Missing audit logging (cannot prove who did what)	Repudiation	Low	Mitigated	4	Without audit logs, malicious actions (profile changes/login attempts) cannot be reliably traced or investigated.	Audit login/logout, failed auth, profile updates; include userId, timestamp, IP, user-agent; store logs in protected/append-only storage.
13	Brute-force / Credential stuffing	Spoofing	High	Mitigated	8	An attacker may attempt to authenticate as another user using repeated password attempts or leaked credential lists.	Rate limit per IP and per account, exponential backoff, CAPTCHA after repeated failures, temporary lockouts, and monitoring of auth anomalies.

PostgreSQL (Store)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
11	Weak password hashing / poor parameters	Information disclosure	High	Mitigated	7	If password hashing is weak, leaked hashes may be cracked leading to credential compromise.	Use Argon2id (or bcrypt with strong cost), unique salt per user, and periodically review parameters; protect backups and secrets.

Register/Login/Update Profile (HTTPS) (Data Flow)

Number	Title	Type	Severity	Status	Score	Description	Mitigations
3	Credential interception / MITM	Information disclosure	Critical	Mitigated	9	Credentials or session data may be intercepted if communication between the client and backend is not properly encrypted.	Enforce HTTPS everywhere, enable HSTS, disable HTTP endpoints, and use modern TLS configuration.

Number	Title	Type	Severity	Status	Score	Description	Mitigations
10	DoS via registration/login flooding	Denial of service	Medium	Mitigated	5	Attackers may overwhelm authentication endpoints, degrading availability for legitimate users.	Rate limiting, request throttling, bot protection (CAPTCHA), and protective controls at gateway/load balancer.